

Cirque Corporation

Information Security Incident Management Policy

Document ID: IS-CIRQ-P-014-G

Category: IT Security Related

Division: Policy

Type: Global

Version: 1.0

Effective Date: 2025-07-01

Review Date: 2026-07-01

Approved By: Executive Committee

Generated: March 02, 2026

1. Purpose

The purpose of this policy is to establish Cirque's requirements for the effective management of information security incidents. This includes defining a structured approach for reporting, assessing, responding to, resolving, and learning from security incidents. This policy aims to minimize the impact of security incidents, ensure timely recovery, and prevent recurrence, in accordance with ISO/IEC 27001:2022 Annex A.16.

****2. Scope****

2. Scope

This policy applies to all Cirque personnel (employees, contractors, temporary staff), all information assets, information systems, applications, and networks owned or managed by Cirque across all its global operations (US, Taipei, Japan, China). It covers all types of information security incidents, from minor security events to major breaches.

****3. Definitions****

3. Definitions

- ****Information Security Event:**** An identified occurrence of a system, service, or network state indicating a possible breach of information security policy or failure of controls, or a previously unknown situation that may be security relevant.
- ****Information Security Incident:**** A single or a series of unwanted or unexpected information security events that have a significant probability of compromising business operations and threatening information security (e.g., loss of confidentiality, integrity, or availability).
- ****Information Security Breach:**** A security incident that results in the confirmed or suspected unauthorized access, use, disclosure, loss, or theft of sensitive or confidential information.
- ****Incident Response Team (IRT):**** A designated group of individuals responsible for managing and responding to information security incidents.

****4. Principles of Information Security Incident Management****

4. Principles of Information Security Incident Management

Cirque is committed to managing information security incidents effectively based on the following principles:

- ****Timeliness:**** Incidents shall be reported, assessed, and responded to as quickly as possible to minimize potential damage.
- ****Containment and Recovery:**** Efforts shall focus on containing the incident and restoring affected services and data to normal

operation in a timely manner.

- **Learning and Improvement:** Incidents shall be analyzed to identify root causes and implement corrective actions to prevent recurrence.
- **Compliance:** All incident management activities shall comply with relevant legal, regulatory, and contractual obligations, including data breach notification requirements.
- **Communication:** Clear and effective communication shall be maintained with relevant stakeholders throughout the incident lifecycle.

5. Information Security Incident Management Requirements

5. Information Security Incident Management Requirements

5.1. Incident Reporting: a. All Cirque personnel are responsible for reporting any suspected or actual information security event or incident immediately upon discovery. b. Reporting channels shall be clearly communicated (e.g., direct contact with IT Manager, dedicated email alias, ticketing system). c. Reports shall include as much detail as possible about the event, including time, location, affected systems, and observations.

5.2. Incident Assessment and Classification: a. Upon receiving an incident report, the IT Manager (or designated IT personnel) shall promptly assess the event to determine if it constitutes an information security incident. b. Incidents shall be classified based on their severity, impact on business operations, and potential for data compromise (e.g., Low, Medium, High, Critical). This classification will guide response prioritization.

****5.3. Incident Response and Management:**** a. An ****Incident Response Team (IRT)****, led by the IT Manager, shall be established with clearly defined roles and responsibilities for handling incidents. b. The incident response process shall follow defined steps, typically including: * ****Preparation:**** Establishing tools, processes, and training for incident handling. * ****Detection & Analysis:**** Identifying and understanding the scope and nature of the incident. * ****Containment:**** Limiting the damage and preventing further spread of the incident. * ****Eradication:**** Removing the cause of the incident (e.g., malware, unauthorized access). * ****Recovery:**** Restoring affected systems and data to normal operations. * ****Post-Incident Activity:**** Lessons learned, reporting, and preventive actions. c. Specific procedures shall be developed for common incident types (e.g., malware infection, unauthorized access, data loss, denial of service attacks, phishing).

****5.4. Communication and Escalation:**** a. Clear communication channels shall be established for internal and, where necessary, external stakeholders (e.g., customers, regulatory authorities, law enforcement). b. Incidents shall be escalated based on their classification and potential impact. Critical incidents (e.g., data breaches) require immediate notification to executive management. c. Legal counsel shall be consulted for incidents that may have legal or regulatory implications, particularly concerning data breach notification requirements.

****5.5. Evidence Collection and Preservation:**** a. During an incident, all relevant evidence (e.g., logs, forensic images, physical devices) shall be collected and preserved in a forensically sound manner to support investigation and potential legal action. b. The chain of custody for evidence shall be maintained.

5.6. Post-Incident Review and Improvement: a. After an incident is resolved, a post-incident review (lessons learned) shall be conducted, especially for significant incidents. b. The review shall identify: * What happened, when, and how. * The root cause of the incident. * Effectiveness of the response actions. * Impact of the incident. * Recommendations for preventing recurrence and improving incident response capabilities. c. Corrective actions identified during the review shall be tracked and implemented (refer to IS-CIRQ-PR-013-G: Change Management Procedure).

5.7. Compliance and Reporting: a. Cirque shall comply with all applicable laws and regulations regarding information security incident reporting and data breach notifications (e.g., GDPR, CCPA, industry-specific regulations). b. Records of all incidents, their handling, and outcomes shall be maintained for audit and compliance purposes.

6. Responsibilities

- **IT Manager:** Acts as the Incident Response Team Lead. Responsible for coordinating all incident management activities, ensuring resources are available, and reporting to executive management.
- **All Personnel:** Responsible for prompt reporting of suspected incidents.
- **Executive Committee:** Provides strategic oversight and approves significant resources for incident management.
- **Legal Counsel:** Provides guidance on legal and regulatory compliance, particularly for data breaches.

****7. Related Documents****

7. Related Documents

- IS-CIRQ-PR-020-G: Incident Response Procedure (Global Core)
- IS-CIRQ-P-001-G: Information Security Policy
- IS-CIRQ-P-011-G: Operations Security Policy
- IS-CIRQ-PR-015-G: Logging and Monitoring Procedure
- IS-CIRQ-PR-013-G: Change Management Procedure
- IS-CIRQ-F-001-G: Risk Assessment Register

****8. Policy Review****

8. Policy Review

This policy will be reviewed at least annually, or sooner if there are significant changes to Cirque's operations, legal/regulatory landscape, or lessons learned from incidents.